

情報セキュリティ 応用情報技術者過去問題 令和元年 秋期 午後問1

要約(詳細は

https://www.jitec.ipa.go.jp/1_04hanni_sukiru/mondai_kaitou_2019h31_2/2019r01a_ap_pm_qs.pdf 参
照)

- ・P社では顧客との連携やファイルのやり取りに電子メールを利用している
- ・従業員にはPCが一台貸与され、メールクライアントソフトを使う。受信にはPOP3, 送信にはSMTPを使い、受信だけにパスワード認証を行っている。
- ・PCはケーブル配線で社内LANに接続され、インターネットへのアクセスはファイアウォール(FW)でHTTP,HTTPSだけ許可
- ・社内情報共有のポータルサイトのために、社内LAN上のWebサーバを利用している。
- ・図1はP社のネットワーク構成の一部で社内LAN及びDMZ上の機器には、固定のIPアドレスが割り当てられている

[P社に届いた不審なメール]

- ・ある日、P社に不審なメールが届いた。ヘッダを確認したところ、送信元メールアドレスのドメインはP社以外とだった。
 - ・X部長は、Yさんに不審メールの調査を指示した
 - ・聞き取り調査の結果、設計部のZさんも不審メールを受信して、添付ファイルを実行していることがわかった。
- Yさんは、Zさんが仕様しているPC(被疑PC)のケーブルを①ネットワークから切り離し、P社ネットワーク運用を委託しているQ社に調査を依頼した
- ・Q社で被疑PCを調査した結果、不審なプロセスが挙動しており、インターネット上の特定のサーバと不審な通信を試みていた。不審な通信にはSSHを使用していたので、②特定のサーバとの通信には失敗していた。また、Q社は[a]のログを分析して不審な通信が被疑PC以外に観測されていないので、被害はないと判断した。

(1): 下線①で、Yさんが被疑PCをネットワークから切り離した目的を20文字以内で述べよ

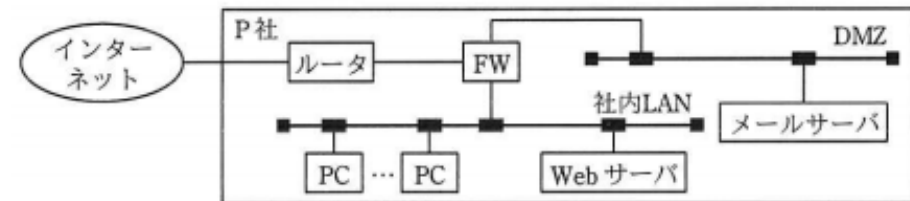


図1 P社のネットワーク構成（一部）

P社従業員の皆様
総務部長のXです。

通達でお知らせしたとおり、PCで利用しているアプリケーションソフトウェアの調査を依頼します。このメールに情報収集ツールを添付しましたので、圧縮された添付ファイルを次に示すパスワードを使ってPC上で展開の上、情報収集ツールを実行して、画面の指示に従ってください。

図2 不審メールの文面（抜粋）

- ・ P社では顧客との連携やファイルのやり取りに電子メールを利用している
- ・ 従業員にはPCが一台貸与され、メールクライアントソフトを使う。受信にはPOP3, 送信にはSMTPを使い、受信だけにパスワード認証を行っている。
- ・ PCはケーブル配線で社内LANに接続され、インターネットへのアクセスはファイアウォール(FW)でHTTP,HTTPSだけ許可
- ・ 社内情報共有のポータルサイトのために、社内LAN上のWebサーバを利用している。
- ・ 図1はP社のネットワーク構成の一部で社内LAN及びDMZ上の機器には、固定のIPアドレスが割り当てられている

[P社に届いた不審なメール]

- ・ ある日、P社に不審なメールが届いた。ヘッダを確認したところ、送信元メールアドレスのドメインはP社以外とだった。
 - ・ X部長は、Yさんに不審メールの調査を指示した
 - ・ 聞き取り調査の結果、設計部のZさんも不審メールを受信して、添付ファイルを実行していることがわかった。
- Yさんは、Zさんが仕様しているPC(被疑PC)のケーブルを①ネットワークから切り離し、P社ネットワーク運用を委託しているQ社に調査を依頼した
- ・ Q社で被疑PCを調査した結果、不審なプロセスが挙動しており、インターネット上の特定のサーバと不審な通信を試みていた。不審な通信にはSSHを使用していたので、②特定のサーバとの通信には失敗していた。また、Q社は[a]のログを分析して不審な通信が被疑PC以外に観測されていないので、被害はないと判断した。

(1): 下線①で、Yさんが被疑PCをネットワークから切り離した目的を20文字以内で述べよ

答え: 社内の他の機器と通信させないため

マルウェアに感染が疑われる場合には、PCをネットワークから切り離します。ネットワークを経由して、マルウェアが他のPCに影響を及ぼさないためです。

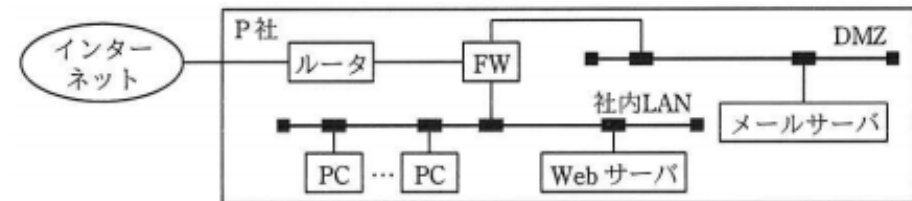


図1 P社のネットワーク構成（一部）

P社従業員の皆様
総務部長のXです。

通達でお知らせしたとおり、PCで利用しているアプリケーションソフトウェアの調査を依頼します。このメールに情報収集ツールを添付しましたので、圧縮された添付ファイルを次に示すパスワードを使ってPC上で展開の上、情報収集ツールを実行して、画面の指示に従ってください。

図2 不審メールの文面（抜粋）

- ・ P社では顧客との連携やファイルのやり取りに電子メールを利用している
- ・ 従業員にはPCが一台貸与され、メールクライアントソフトを使う。受信にはPOP3, 送信にはSMTPを使い、受信だけにパスワード認証を行っている。
- ・ PCはケーブル配線で社内LANに接続され、インターネットへのアクセスはファイアウォール(FW)でHTTP,HTTPSだけ許可
- ・ 社内情報共有のポータルサイトのために、社内LAN上のWebサーバを利用している。
- ・ 図1はP社のネットワーク構成の一部で社内LAN及びDMZ上の機器には、固定のIPアドレスが割り当てられている

[P社に届いた不審なメール]

- ・ ある日、P社に不審なメールが届いた。ヘッダを確認したところ、送信元メールアドレスのドメインはP社以外とだった。
 - ・ X部長は、Yさんに不審メールの調査を指示した
 - ・ 聞き取り調査の結果、設計部のZさんも不審メールを受信して、添付ファイルを実行していることがわかった。
- Yさんは、Zさんが仕様しているPC(被疑PC)のケーブルを①ネットワークから切り離し、P社ネットワーク運用を委託しているQ社に調査を依頼した
- ・ Q社で被疑PCを調査した結果、不審なプロセスが挙動しており、インターネット上の特定のサーバと不審な通信を試みていた。不審な通信にはSSHを使用していたので、②特定のサーバとの通信には失敗していた。また、Q社は[a]のログを分析して不審な通信が被疑PC以外に観測されていないので、被害はないと判断した。

(2):本文中の下線②で、不審なプロセスが特定のサーバとの通信に失敗した理由を20字以内で述べよ。

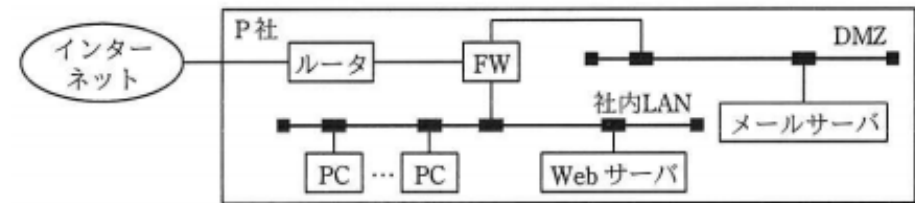


図1 P社のネットワーク構成（一部）

P社従業員の皆様
総務部長のXです。

通達でお知らせしたとおり、PCで利用しているアプリケーションソフトウェアの調査を依頼します。このメールに情報収集ツールを添付しましたので、圧縮された添付ファイルを次に示すパスワードを使ってPC上で展開の上、情報収集ツールを実行して、画面の指示に従ってください。

図2 不審メールの文面（抜粋）

- ・ P社では顧客との連携やファイルのやり取りに電子メールを利用している
- ・ 従業員にはPCが一台貸与され、メールクライアントソフトを使う。受信にはPOP3, 送信にはSMTPを使い、受信だけにパスワード認証を行っている。
- ・ PCはケーブル配線で社内LANに接続され、インターネットへのアクセスはファイアウォール(FW)でHTTP,HTTPSだけ許可
- ・ 社内情報共有のポータルサイトのために、社内LAN上のWebサーバを利用している。
- ・ 図1はP社のネットワーク構成の一部で社内LAN及びDMZ上の機器には、固定のIPアドレスが割り当てられている

[P社に届いた不審なメール]

- ・ ある日、P社に不審なメールが届いた。ヘッダを確認したところ、送信元メールアドレスのドメインはP社以外とだった。
 - ・ X部長は、Yさんに不審メールの調査を指示した
 - ・ 聞き取り調査の結果、設計部のZさんも不審メールを受信して、添付ファイルを実行していることがわかった。
- Yさんは、Zさんが仕様しているPC(被疑PC)のケーブルを①ネットワークから切り離し、P社ネットワーク運用を委託しているQ社に調査を依頼した
- ・ Q社で被疑PCを調査した結果、不審なプロセスが挙動しており、インターネット上の特定のサーバと不審な通信を試みていた。不審な通信にはSSHを使用していたので、②特定のサーバとの通信には失敗していた。また、Q社は[a]のログを分析して不審な通信が被疑PC以外に観測されていないので、被害はないと判断した。

(2):本文中の下線②で、不審なプロセスが特定のサーバとの通信に失敗した理由を20字以内で述べよ。

答え: FWでアクセスが許可されていないから
直前にSSHを使用していたのでという記述があります。これが通信に失敗した原因で、理由はFWでインターネットへのアクセスをHTTP,HTTPSだけ許可していたことです。

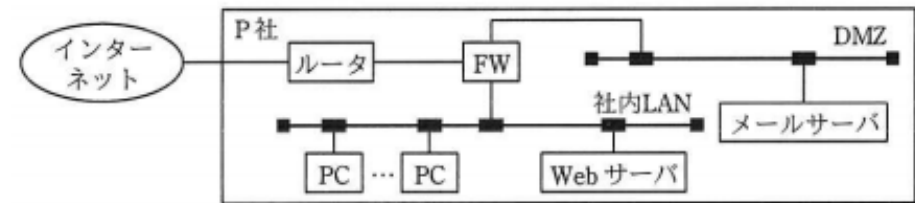


図1 P社のネットワーク構成（一部）

P社従業員の皆様
総務部長のXです。

通達でお知らせしたとおり、PCで利用しているアプリケーションソフトウェアの調査を依頼します。このメールに情報収集ツールを添付しましたので、圧縮された添付ファイルを次に示すパスワードを使ってPC上で展開の上、情報収集ツールを実行して、画面の指示に従ってください。

図2 不審メールの文面（抜粋）

- ・P社では顧客との連携やファイルのやり取りに電子メールを利用している
- ・従業員にはPCが一台貸与され、メールクライアントソフトを使う。受信にはPOP3, 送信にはSMTPを使い、受信だけにパスワード認証を行っている。
- ・PCはケーブル配線で社内LANに接続され、インターネットへのアクセスはファイアウォール(FW)でHTTP,HTTPSだけ許可
- ・社内情報共有のポータルサイトのために、社内LAN上のWebサーバを利用している。
- ・図1はP社のネットワーク構成の一部で社内LAN及びDMZ上の機器には、固定のIPアドレスが割り当てられている

[P社に届いた不審なメール]

- ・ある日、P社に不審なメールが届いた。ヘッダを確認したところ、送信元メールアドレスのドメインはP社以外とだった。
 - ・X部長は、Yさんに不審メールの調査を指示した
 - ・聞き取り調査の結果、設計部のZさんも不審メールを受信して、添付ファイルを実行していることがわかった。
- Yさんは、Zさんが仕様しているPC(被疑PC)のケーブルを①ネットワークから切り離し、P社ネットワーク運用を委託しているQ社に調査を依頼した
- ・Q社で被疑PCを調査した結果、不審なプロセスが挙動しており、インターネット上の特定のサーバと不審な通信を試みていた。不審な通信にはSSHを使用していたので、②特定のサーバとの通信には失敗していた。また、Q社は[a]のログを分析して不審な通信が被疑PC以外に観測されていないので、被害はないと判断した。

(3):本文中のaに入れる適切な字句を、図1中の構成機器の名称で答えよ

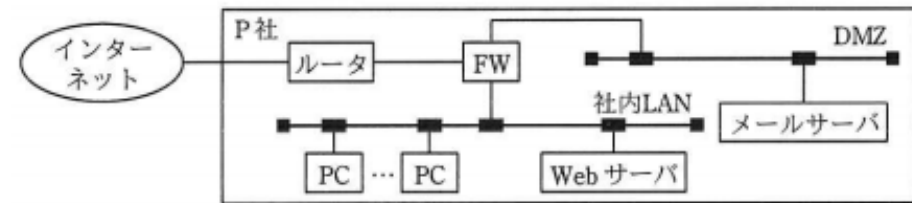


図1 P社のネットワーク構成（一部）

P社従業員の皆様
総務部長のXです。

通達でお知らせしたとおり、PCで利用しているアプリケーションソフトウェアの調査を依頼します。このメールに情報収集ツールを添付しましたので、圧縮された添付ファイルを次に示すパスワードを使ってPC上で展開の上、情報収集ツールを実行して、画面の指示に従ってください。

図2 不審メールの文面（抜粋）

- ・P社では顧客との連携やファイルのやり取りに電子メールを利用している
- ・従業員にはPCが一台貸与され、メールクライアントソフトを使う。受信にはPOP3, 送信にはSMTPを使い、受信だけにパスワード認証を行っている。
- ・PCはケーブル配線で社内LANに接続され、インターネットへのアクセスはファイアウォール(FW)でHTTP,HTTPSだけ許可
- ・社内情報共有のポータルサイトのために、社内LAN上のWebサーバを利用している。
- ・図1はP社のネットワーク構成の一部で社内LAN及びDMZ上の機器には、固定のIPアドレスが割り当てられている

[P社に届いた不審なメール]

- ・ある日、P社に不審なメールが届いた。ヘッダを確認したところ、送信元メールアドレスのドメインはP社以外とだった。
 - ・X部長は、Yさんに不審メールの調査を指示した
 - ・聞き取り調査の結果、設計部のZさんも不審メールを受信して、添付ファイルを実行していることがわかった。
- Yさんは、Zさんが仕様しているPC(被疑PC)のケーブルを①ネットワークから切り離し、P社ネットワーク運用を委託しているQ社に調査を依頼した
- ・Q社で被疑PCを調査した結果、不審なプロセスが挙動しており、インターネット上の特定のサーバと不審な通信を試みていた。不審な通信にはSSHを使用していたので、②特定のサーバとの通信には失敗していた。また、Q社は[a]のログを分析して不審な通信が被疑PC以外に観測されていないので、被害はないと判断した。

(3):本文中のaに入れる適切な字句を、図1中の構成機器の名称で答えよ

答え: FW

直後に不審な通信が被疑PC以外に観測されていないことを確認しています。このことから、他のPCからのアクセスがないか確認するためにログを用いていることがわかります。FWのログをみることで、不審な通信を確認することができます。(FWで遮断されるため、ルータまでは届かない)

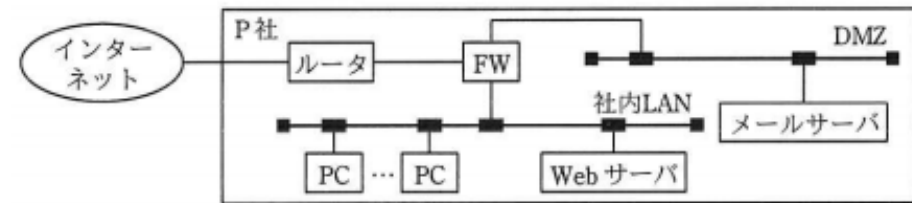


図1 P社のネットワーク構成（一部）

P社従業員の皆様
総務部長のXです。

通達でお知らせしたとおり、PCで利用しているアプリケーションソフトウェアの調査を依頼します。このメールに情報収集ツールを添付しましたので、圧縮された添付ファイルを次に示すパスワードを使ってPC上で展開の上、情報収集ツールを実行して、画面の指示に従ってください。

図2 不審メールの文面（抜粋）

- ・この教訓をもとに、情報セキュリティ対策として、図1の社内LANのネットワーク構成を変更せずに実施できる技術的検討をQ社に依頼するように、x部長はYさんに指示した。
- ・Q社のYさんは、P社で実施済みの情報セキュリティ対策のうち、標的型サーバー攻撃に有効な技術対策を確認し、表1にまとめた
- ・W氏は、表1の対策を踏まえて、表2で示す、新たな情報セキュリティ対策案をYさんに示した

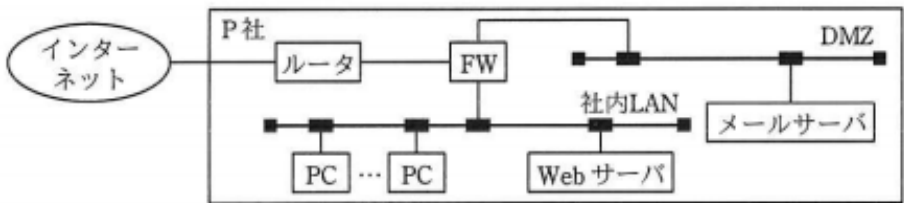


図1 P社のネットワーク構成（一部）

表1 標的型サイバー攻撃に有効なP社で実施済みの情報セキュリティ対策（一部）

対策の名称	対策の内容
FWによる遮断	・ PC からインターネットへのアクセスには、FW で HTTP 及び HTTPS だけを許可し、それ以外は遮断する。
PC へのマルウェア対策ソフトの導入	・ PC にマルウェア対策ソフトを導入し、定期的にパターンファイルの更新と PC 上の全ファイルのチェックを行う。 ・ リアルタイムスキャンを有効化する。

設問 2

(1):表2中のbに入れる字句を解答群の中から選ぶ
ア. OP25B イ. PGP ウ. S/MIME エ. SPF

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・ メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・ PC からメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・ PC から直接インターネットにアクセスすることを禁止（FW で遮断）し、DMZ に新たに設置するプロキシサーバ経由でアクセスさせる。 ・ プロキシサーバでは、利用者 ID とパスワードによる利用者認証を導入する。 ・ プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含む URL フィルタリング機能を導入する。
ログ監視対策	・ Q 社のログ監視サービスを利用して、FW 及びプロキシサーバのログ監視を行い、不審な通信を検知する。

- ・この教訓をもとに、情報セキュリティ対策として、図1の社内LANのネットワーク構成を変更せずに実施できる技術的検討をQ社に依頼するように、x部長はYさんに指示した。
- ・Q社のYさんは、P社で実施済みの情報セキュリティ対策のうち、標的型サーバー攻撃に有効な技術対策を確認し、表1にまとめた
- ・W氏は、表1の対策を踏まえて、表2で示す、新たな情報セキュリティ対策案をYさんに示した

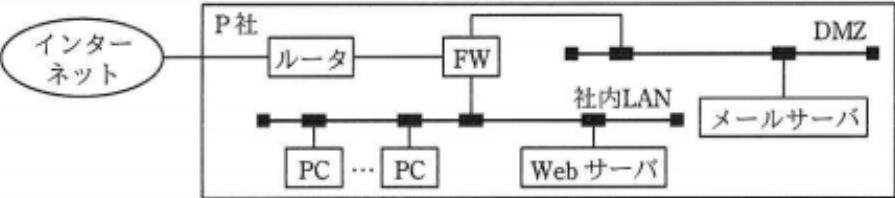


図1 P社のネットワーク構成（一部）

表1 標的型サイバー攻撃に有効なP社で実施済みの情報セキュリティ対策（一部）

対策の名称	対策の内容
FWによる遮断	・PCからインターネットへのアクセスには、FWでHTTP及びHTTPSだけを許可し、それ以外は遮断する。
PCへのマルウェア対策ソフトの導入	・PCにマルウェア対策ソフトを導入し、定期的にパターンファイルの更新とPC上の全ファイルのチェックを行う。 ・リアルタイムスキャンを有効化する。

設問2

(1):表2中のbに入れる字句を解答群の中から選ぶ
ア. OP25B イ. PGP ウ. S/MIME **エ. SPF**

SPFはSender Policy Frameworkと言って、電子メールの送信元のドメイン情報と、電子メールを送信したサーバのIPアドレスから、ドメインの詐称がないことを確認するドメイン認証技術です。
OP25Bは、スパムメールの送信を防ぐ仕組みです。
PGPは、公開鍵暗号方式を使用して通信当事者間でファイルや電子メールの「暗号化」「認証」「改ざん検知」をします
S/MIMEは、「暗号化」「認証」「改ざん検知」機能を電子メールソフトに提供する技術です

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PCから直接インターネットにアクセスすることを禁止（FWで遮断）し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	・Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

Yさん：メールサーバに導入する送信ドメイン認証は、標的型サイバー攻撃にどのような効果がありますか。

W氏：送信ドメイン認証は、メールの[c]を検知できます。

Yさん：メールサーバで送信する際に利用者認証を行う理由は？

W氏：標的型サイバー攻撃の目的が情報窃取だった場合、メール経由で情報が外部に漏えいするおそれがあります。利用者認証を行うことでそのようなリスクを低減できます。

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

表 2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PC からメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PC から直接インターネットにアクセスすることを禁止（FW で遮断）し、DMZ に新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者 ID とパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含む URL フィルタリング機能を導入する。
ログ監視対策	・Q 社のログ監視サービスを利用して、FW 及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(2): [c], [d]に入れる適切な字句を、20文字以内で答えよ

Yさん：メールサーバに導入する送信ドメイン認証は、標的型サイバー攻撃にどのような効果がありますか。

W氏：送信ドメイン認証は、メールの[c]を検知できます。

Yさん：メールサーバで送信する際に利用者認証を行う理由は？

W氏：標的型サイバー攻撃の目的が情報窃取だった場合、メール経由で情報が外部に漏えいするおそれがあります。利用者認証を行うことでそのようなリスクを低減できます。

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

表 2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PC からメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PC から直接インターネットにアクセスすることを禁止（FW で遮断）し、DMZ に新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者 ID とパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含む URL フィルタリング機能を導入する。
ログ監視対策	・Q 社のログ監視サービスを利用して、FW 及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(2): [c], [d]に入れる適切な字句を、20文字以内で答えよ

c: 送信元メールアドレスのなりすまし

送信ドメイン認証では、送信元メールサーバのIPアドレスとドメイン名が一致するのかを確認するために行います。これを行うことで送信元メールアドレスのなりすましを検知できます

Yさん：メールサーバに導入する送信ドメイン認証は、標的型サイバー攻撃にどのような効果がありますか。

W氏：送信ドメイン認証は、メールの[c]を検知できます。

Yさん：メールサーバで送信する際に利用者認証を行う理由は？

W氏：標的型サイバー攻撃の目的が情報窃取だった場合、メール経由で情報が外部に漏えいするおそれがあります。利用者認証を行うことでそのようなリスクを低減できます。

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

表 2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PC からメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PC から直接インターネットにアクセスすることを禁止（FW で遮断）し、DMZ に新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者 ID とパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含む URL フィルタリング機能を導入する。
ログ監視対策	・Q 社のログ監視サービスを利用して、FW 及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(2): [c], [d]に入れる適切な字句を、20文字以内で答えよ

d: HTTPまたはHTTPS

通信ができなかった理由はSSHだったためです。FWはHTTPとHTTPSの通信は許可しているので、通信プロトコルがHTTPまたはHTTPSの場合は、通信が成功していました。

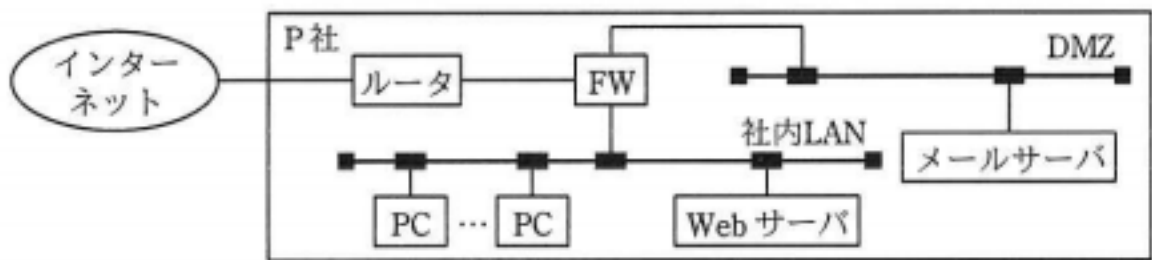


図1 P社のネットワーク構成(一部)

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をx部長に報告した。報告を受けたx部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

サイ
メール経由
行うこ

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PCから直接インターネットにアクセスすることを禁止(FWで遮断)し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	・Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(3): 本文中の下線③の水飲み場攻撃では、どこかにあらかじめ仕込んでおいたマルウェアをダウンロードするように仕向ける。マルウェアはどこに仕込まれる可能性が高いか、適切な内容を解答群の中から選び、記号で答えよ。

- ア. P社従業員がよく利用するサイト
- イ. P社従業員の利用が少ないサイト
- ウ. P社のプロキシサーバ
- エ. P社のメールサーバ

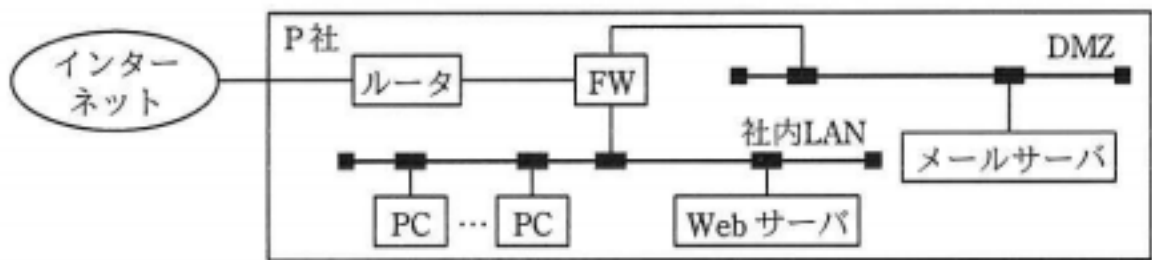


図1 P社のネットワーク構成(一部)

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

サイ
メール経由
行うこ

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PCから直接インターネットにアクセスすることを禁止(FWで遮断)し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	・Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(3): 本文中の下線③の水飲み場攻撃では、どこかにあらかじめ仕込んでおいたマルウェアをダウンロードするように仕向ける。マルウェアはどこに仕込まれる可能性が高いか、適切な内容を解答群の中から選び、記号で答えよ。

- ア. P社従業員がよく利用するサイト**
水飲み場型攻撃は、ユーザが利用するWebサイトなどからダウンロードさせる攻撃で、従業員がよく利用するサイトに仕込まれます
イ. P社従業員の利用が少ないサイト
ウ. P社のプロキシサーバ
エ. P社のメールサーバ

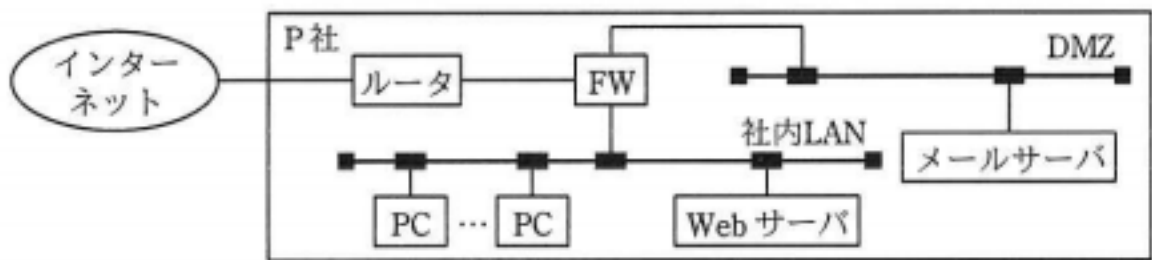


図1 P社のネットワーク構成(一部)

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

サイ
メール経由
行うこ

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PCから直接インターネットにアクセスすることを禁止(FWで遮断)し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	・Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

- (4): 本文中の下線④で、C&CサーバがURLフィルタリング機能でアクセスが遮断されないサイトに設置された場合、マルウェアがどのような機能を備えていると対策を回避されてしまうか、適切な内容を解答群の中から選び、記号で答えよ。
- ア. PC上のファイルを暗号化する機能
 - イ. 感染後にしばらく潜伏してから攻撃を開始する機能
 - ウ. 自身の亜種を作成する機能
 - エ. プロキシサーバの利用者認証情報を窃取する機能

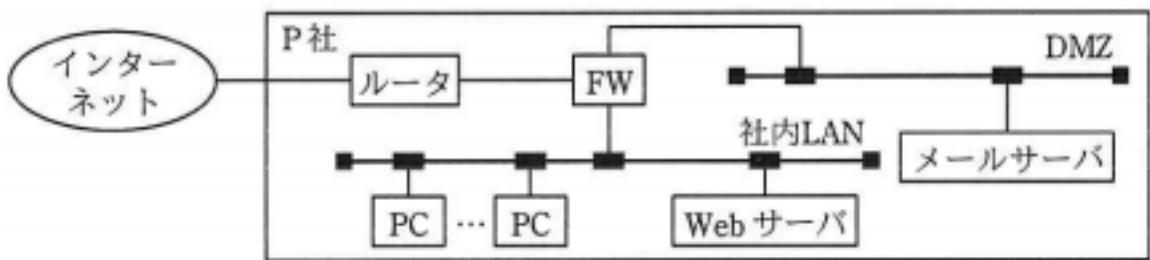


図1 P社のネットワーク構成（一部）

- ア. PC上のファイルを暗号化する機能
- イ. 感染後にしばらく潜伏してから攻撃を開始する機能
- ウ. 自身の亜種を作成する機能
- エ. プロキシサーバの利用者認証情報を窃取する機能

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。
W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。
Yさん：ログ監視対策の目的も教えてください。
W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

サイ
メール経由
行うこ

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PCから直接インターネットにアクセスすることを禁止（FWで遮断）し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	・Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(4): 本文中の下線④で、C&CサーバがURLフィルタリング機能でアクセスが遮断されないサイトに設置された場合、マルウェアがどのような機能を備えていると対策を回避されてしまうか、適切な内容を解答群の中から選び、記号で答えよ。
エ. プロキシサーバの利用者認証情報を窃取する機能
P社はプロキシサーバの利用者認証によるインターネットへのアクセス対策をしている。しかし、マルウェアがプロキシサーバの利用者認証情報を搾取する機能を持つとこの対策を回避されてしまう

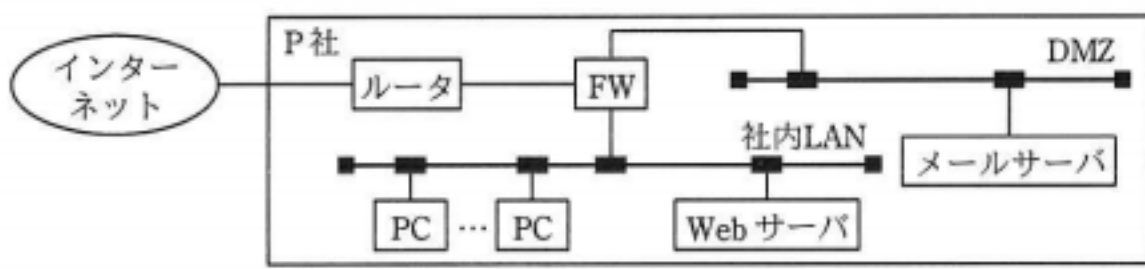


図1 P社のネットワーク構成（一部）

Yさん：インターネットアクセス対策は、今回の不審な通信に対してどのような効果がありますか。

W氏：今回の不審な通信は特定のサーバとの通信に失敗したが、マルウェアが使用する通信プロトコルが[d]だった場合、サイバー攻撃の被害が拡大していたおそれがあった。その場合も、表2に示したインターネットアクセス対策を導入すると防げる可能性が高まります。

Yさん：URLフィルタリング機能は、どのようなリスクへの対策か。

W氏：標的型サイバー攻撃はメール経由とは限りません。例えば、③水飲み場攻撃によってマルウェアをダウンロードさせられることがある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

サイ

メール経由
行うこ

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	- メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 [b]などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	- PCから直接インターネットにアクセスすることを禁止（FWで遮断）し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 - プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 - プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(5) の適切な取扱いに関して適切なもの

ア. PCのメールクライアントソフトを再インストールする。

イ. 不審なメールが届いたことをP社の情報システム担当に連絡する。

ウ. 不審なメールの本文と添付ファイルをPCに保存する。

エ. 不審なメールの本文に書かれているURLにアクセスして真偽を確認する。

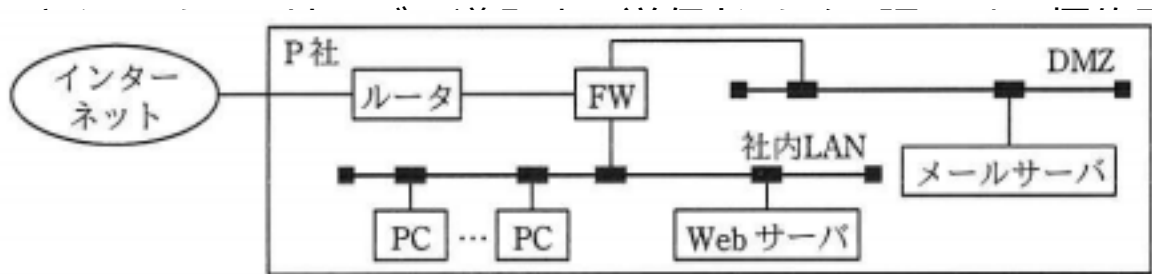


図1 P社のネットワーク構成（一部）

サイ
ル経由
行うこ

(5) に関する解答群

ア. PCのメールクライアントソフトを再インストールする。

イ. 不審なメールが届いたことをP社の情報システム担当に連絡する。

ウ. 不審なメールの本文と添付ファイルをPCに保存する。

エ. 不審なメールの本文に書かれているURLにアクセスして真偽を確認する。

ある。URLフィルタリング機能で、そのような被害を軽減できます。

Yさん：ログ監視対策の目的も教えてください。

W氏：表2に示したインターネットアクセス対策を導入した場合でも、高度な標的型サイバー攻撃が行われると、④こちらが講じた対策を回避してC&C(Command and Control)サーバと通信されてしまうおそれがある。その場合に行われる不審な通信を検知するためにログ監視を行う。

W氏から説明を受けたYさんは、Q社から提案された新たな情報セキュリティ対策案をX部長に報告した。報告を受けたX部長は、各対策を導入する計画を立てるとともに、⑤不審なメールの適切な取扱いについて従業員に周知するように、Yさんに指示した。

表2 標的型サイバー攻撃に有効な新たな情報セキュリティ対策案

対策の名称	対策の内容
メールサーバにおけるメール受信対策	・メールサーバ向けマルウェア対策ソフトを導入して、届いたメールの本文や添付ファイルのチェックを行い、不審なメールは隔離する。 ・ b などの送信ドメイン認証を導入する。
メールサーバにおけるメール送信対策	・PCからメールを送信する際にも、利用者認証を行う。
インターネットアクセス対策	・PCから直接インターネットにアクセスすることを禁止（FWで遮断）し、DMZに新たに設置するプロキシサーバ経由でアクセスさせる。 ・プロキシサーバでは、利用者IDとパスワードによる利用者認証を導入する。 ・プロキシサーバでは、不正サイトや改ざんなどで侵害されたサイトを遮断する機能を含むURLフィルタリング機能を導入する。
ログ監視対策	・Q社のログ監視サービスを利用して、FW及びプロキシサーバのログ監視を行い、不審な通信を検知する。

(5) の適切な取扱いに関して適切なもの

イ. 不審なメールが届いたことをP社の情報システム担当に連絡する。

→正しい対策です。不審なメールが届いた場合、添付ファイルの開封、URLリンクを開くなどをせず、情報システム担当などのセキュリティ対策担当に報告しましょう。